

HiveForce Labs

THREAT ADVISORY



VULNERABILITY REPORT

SonicWall SMA Flaw Leads to Unauthenticated Root Access

Date of Publication

December 18, 2025

Admiralty Code

A1

TA Number

TA2025383

Summary

Discovered On: December 2025

Affected Products: SonicWall SMA1000

Impact: SonicWall released security patches addressing CVE-2025-40602, an actively exploited vulnerability affecting the Secure Mobile Access (SMA) 1000 series Appliance Management Console (AMC). This local privilege escalation vulnerability stems from insufficient authorization controls within the AMC component. Threat actors have been observed chaining this vulnerability with the previously disclosed CVE-2025-23006 to achieve unauthenticated remote code execution with root privileges on affected appliances. SonicWall SMA 1000 appliances are widely deployed by large, distributed enterprises to enable secure remote access to corporate applications, making this vulnerability particularly significant for organizations relying on these devices for secure remote connectivity.

⚙️ CVEs

CVE	NAME	AFFECTED PRODUCT	ZERO-DAY	CISA KEV	PATCH
CVE-2025-40602	SonicWall SMA1000 Missing Authorization Vulnerability	SonicWall SMA1000	❌	✅	✅
CVE-2025-23006	SonicWall SMA1000 Appliances Deserialization Vulnerability	SonicWall SMA1000	✅	✅	✅

Vulnerability Details

#1

SonicWall has released security updates for its Secure Mobile Access (SMA) 1000 series appliances after confirming active exploitation of a newly disclosed vulnerability. The flaw affects the appliance management console and poses a serious risk to organizations that rely on SMA devices for secure remote access.

#2

Tracked as CVE-2025-40602, the issue stems from insufficient authorization controls within the management interface. Under normal conditions, an attacker would need access to a local user account on the device. However, once that access is obtained, the vulnerability allows the attacker to escalate privileges all the way to root, effectively taking full control of the appliance.

#3

What makes this threat particularly dangerous is how it is being exploited in real-world attacks. Threat actors have been observed chaining CVE-2025-40602 with [CVE-2025-23006](#), a critical pre-authentication deserialization flaw. CVE-2025-23006 allows unauthenticated attackers to execute arbitrary OS commands, and when combined with CVE-2025-40602, attackers can escalate their privileges to root level.

#4

Given the confirmed exploitation and the high impact of a successful attack, SonicWall SMA 1000 series customers are strongly advised to apply the available patches immediately. Delaying remediation could leave exposed appliances vulnerable to complete compromise, with potential downstream impacts on network security and remote access infrastructure.



Vulnerabilities

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2025-40602	SMA1000 12.4.3-03093 (platform-hotfix) and earlier versions, 12.5.0-02002 (platform-hotfix) and earlier versions	cpe:2.3:a:sonicwall:sma1000:*.~.*.*.*.*.*.*	CWE-862, CWE-250
CVE-2025-23006	SonicWall SMA1000 Appliance Management Console (AMC) and Central Management Console (CMC) Version 12.4.3-02804 and Earlier	cpe:2.3:h:sonicwall:sma1000*.~.*.*.*.*.*.*	CWE-502

Recommendations



Apply Security Updates Immediately: Install the latest SonicWall patches for SMA 1000 series appliances without delay. These updates fix vulnerabilities that are being actively exploited, and leaving systems unpatched could allow attackers to gain full control of the appliance.



Review System Logs: Analyze AMC access logs and authentication records for indicators of unauthorized access or privilege escalation attempts.



Limit and Secure Administrative Access: Restrict access to the appliance management console to trusted administrators only and ensure it is not directly exposed to the internet. Review all local user accounts, remove any that are unnecessary, and reset credentials if there are signs of suspicious activity.



Monitor for Signs of Exploitation: Regularly review system logs for unusual login attempts, privilege changes, or configuration modifications. Early detection can help prevent attackers from maintaining long-term access to the appliance.



Vulnerability Management: This involves regularly assessing and updating software to address known vulnerabilities. Maintain an inventory of software versions and security patches, and evaluate the security practices of third-party vendors, especially for critical applications and services.



Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0004</u> Privilege Escalation
<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities	<u>T1190</u> Exploit Public-Facing Application	<u>T1068</u> Exploitation for Privilege Escalation
<u>T1059</u> Command and Scripting Interpreter			



Patch Details

Update your SMA1000 product to the latest hotfix release version to address the vulnerability.

Link: <https://psirt.global.sonicwall.com/vuln-detail/SNWLID-2025-0019>



References

<https://psirt.global.sonicwall.com/vuln-detail/SNWLID-2025-0019>

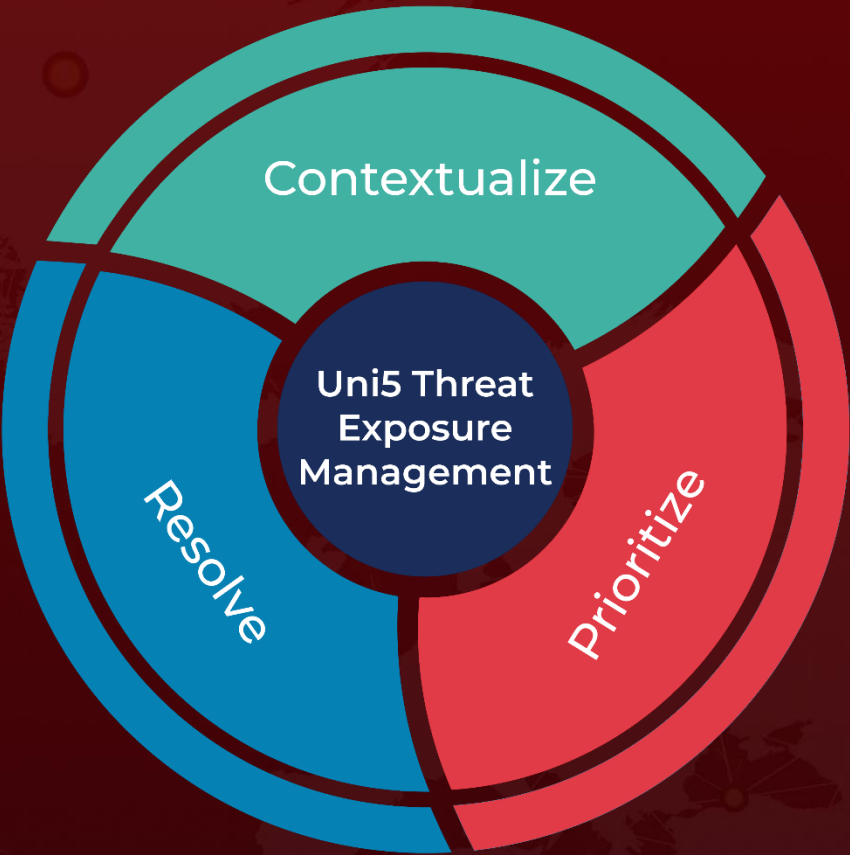
<https://hivepro.com/threat-advisory/sonicwall-sma-1000-faces-active-exploitation-of-critical-vulnerability/>



What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

December 12, 2025 • 8:00 AM

© 2025 All Rights are Reserved by Hive Pro



More at www.hivepro.com